

Il Calcolo del Fattore di Rischio Informatico

Guida metodologica alla valutazione del rischio informatico aziendale,
con riferimenti normativi, formule ed esempio applicativo

Project Work 13 · Tema n.2 – Privacy e sicurezza aziendale

1. Introduzione

Nell'ambito della sicurezza informatica aziendale, il **fattore di rischio** è l'indicatore sintetico che permette di stimare quanto un determinato evento avverso (es. attacco informatico, perdita di dati, indisponibilità di un servizio) possa danneggiare l'organizzazione, e con quale probabilità questo possa accadere. Calcolarlo correttamente consente di stabilire priorità di intervento, allocare risorse in modo efficiente e rispettare gli obblighi normativi in materia di protezione dei dati e continuità operativa.

Questo documento fornisce una guida chiara e applicabile al calcolo del fattore di rischio informatico, illustrando la metodologia con un esempio concreto riferito a un'azienda del settore IT.

2. Riferimenti normativi e standard di riferimento

- **Regolamento (UE) 2016/679 – GDPR** — Art. 32 impone di adottare misure tecniche e organizzative adeguate al rischio, valutato tenendo conto di probabilità e gravità per i diritti e le libertà delle persone fisiche.
- **Direttiva (UE) 2022/2555 – NIS 2** — Introduce obblighi di gestione del rischio per i soggetti essenziali e importanti, incluse valutazioni sistematiche di rischio informatico e obblighi di notifica degli incidenti.
- **ISO/IEC 27001:2022 e ISO/IEC 27005:2022** — Forniscono il framework per il Sistema di Gestione della Sicurezza delle Informazioni (ISMS) e la metodologia dedicata alla gestione del rischio informativo (risk assessment e risk treatment).
- **NIST SP 800-30 Rev.1** — Guida per la conduzione di valutazioni del rischio, con approccio basato su minaccia, vulnerabilità, probabilità e impatto.
- **D.Lgs. 231/2001 e D.Lgs. 81/2008 (per analogia metodologica)** — Pur riferiti ad ambiti diversi (responsabilità amministrativa d'impresa e sicurezza sul lavoro), condividono l'approccio alla valutazione del rischio come prodotto di probabilità e gravità/impatto, qui traslato al contesto informatico.

3. Metodologia di calcolo

Il modello adottato in questo documento si basa sull'approccio più diffuso in letteratura e negli standard ISO/NIST, che esprime il rischio come combinazione di tre componenti:

- **Minaccia (T – Threat)**: evento potenzialmente dannoso (es. malware, phishing, accesso non autorizzato)
- **Vulnerabilità (V – Vulnerability)**: debolezza del sistema che la minaccia può sfruttare
- **Impatto (I – Impact)**: gravità delle conseguenze in caso di evento avverso

Nella pratica operativa, Minaccia e Vulnerabilità vengono spesso aggregate in un unico fattore di **Probabilità (P)** che l'evento si verifichi, semplificando la formula generale:

$$\text{Fattore di Rischio (R)} = \text{Probabilità (P)} \times \text{Impatto (I)}$$

dove sia *P* che *I* sono espressi su una scala numerica discreta da 1 (minimo) a 5 (massimo), secondo le tabelle di riferimento riportate di seguito.

3.1 Scala di Probabilità (P)

Valore	Livello	Descrizione
1	Raro	Evento quasi impossibile, mai verificatosi in azienda
2	Improbabile	Può accadere solo in circostanze eccezionali
3	Possibile	Potrebbe accadere in alcune circostanze
4	Probabile	Accadrà probabilmente nella maggior parte delle circostanze
5	Molto probabile	Ci si attende che accada, anche più volte l'anno

3.2 Scala di Impatto (I)

Valore	Livello	Descrizione
1	Trascurabile	Nessun effetto rilevante su operatività, dati o reputazione
2	Minore	Disservizio limitato, nessuna perdita di dati critici
3	Moderato	Interruzione di un servizio, possibile violazione di dati non sensibili
4	Grave	Violazione di dati personali/sensibili, danno economico significativo
5	Critico	Compromissione totale dei sistemi, violazione massiva di dati, sanzioni GDPR/NIS2

3.3 Matrice di Rischio (Probabilità × Impatto)

Moltiplicando i due valori si ottiene un punteggio da 1 a 25, classificato in quattro fasce di criticità che guidano le priorità di trattamento:

P \ I	1	2	3	4	5
5	5	10	15	20	25
4	4	8	12	16	20
3	3	6	9	12	15
2	2	4	6	8	10
1	1	2	3	4	5

Punteggio	Fascia	Azione raccomandata
1 – 4	Basso	Rischio accettabile, monitoraggio periodico
5 – 9	Medio	Da mitigare in tempi ragionevoli, con controlli aggiuntivi
10 – 15	Alto	Intervento prioritario, misure di mitigazione entro breve termine
16 – 25	Critico	Azione immediata, coinvolgimento del management

4. Esempio applicativo: TechNova Solutions S.r.l.

TechNova Solutions S.r.l. è un'azienda IT fittizia (caso di studio a scopo didattico) che sviluppa software gestionale in cloud per PMI, con circa 40 dipendenti e un data center gestito tramite provider cloud terzo. Di seguito il calcolo del fattore di rischio per tre scenari rappresentativi individuati durante l'analisi.

Asset / Scenario	Minaccia	P	I	R = P×I	Fascia
Server applicativo cloud	Attacco ransomware su endpoint amministrativo	3	5	15	Alto
Database clienti (dati personali)	Accesso non autorizzato per credenziali deboli	4	5	20	Critico
Sito web aziendale	Attacco DDoS con temporanea indisponibilità del servizio	3	2	6	Medio
Postazioni di lavoro	Phishing verso i dipendenti	4	3	12	Alto

4.1 Interpretazione dei risultati

Lo scenario più critico riguarda il **database clienti** ($R = 20$): trattandosi di dati personali, un accesso non autorizzato comporterebbe non solo un danno economico e reputazionale, ma anche obblighi di notifica al Garante Privacy entro 72 ore ai sensi dell'art. 33 GDPR, oltre a possibili sanzioni. Per questo scenario si raccomanda l'adozione immediata di autenticazione a più fattori (MFA), politiche di password robuste e monitoraggio degli accessi (logging e alerting).

Gli scenari relativi a ransomware e phishing ($R = 15$ e $R = 12$) richiedono interventi prioritari ma pianificabili nel breve periodo: formazione del personale, sistemi anti-malware aggiornati e backup periodici testati (regola del 3-2-1).

Il rischio di indisponibilità del sito web ($R = 6$) rientra in fascia media: è opportuno predisporre misure di mitigazione (es. servizio anti-DDoS, CDN) ma senza carattere di urgenza.

5. Conclusioni e buone pratiche

Il calcolo sistematico del fattore di rischio informatico consente alle organizzazioni di trasformare una percezione soggettiva della sicurezza in un processo decisionale oggettivo e ripetibile, in linea con quanto richiesto da GDPR, NIS2 e dagli standard ISO/IEC 27001-27005. Si raccomanda di:

- Aggiornare periodicamente la valutazione del rischio (almeno annualmente o dopo cambiamenti significativi dell'infrastruttura)
- Coinvolgere referenti tecnici e organizzativi nella stima di probabilità e impatto
- Documentare le misure di mitigazione adottate per ciascun rischio identificato
- Integrare la valutazione del rischio nel più ampio Sistema di Gestione della Sicurezza delle Informazioni (ISMS)